

Information Security Program

(insert company name here)

Version (add number)

Effective Date: (add the date when the plan is adopted)

Last Revision Date: (add the date of the last revision of the document)

TABLE OF CONTENTS

INTRODUCTION TO INFORMATION SECURITY PROGRAM	4
Purpose	4
Background	4
Scope	4
Roles and Responsibilities	5
ACCESS MANAGEMENT	7
User Accounts	7
DATA PROTECTION	8
Data Classification	8
Data Loss Prevention	8
Data Breach Identification System Logging and Monitoring	9
Data Breach Management	9
Encryption of the Hard Drive or Laptop	10
Multi-Factor Authentication	11
Technology Equipment Disposal	11
DATA BACKUPS AND DISASTER RECOVERY	12
Backup Plan	12
EMPLOYEE MANAGEMENT	13
Shared Device Workstation	13
Remote Access	13
Social Engineering	13
Equipment	14
Employee Training/ User Awareness	14
IT Prohibited Use	14
Wireless Communication	15
Clean Desk	16
PASSWORD REQUIREMENTS	17
Password Standards	17
Password Standards for Administrative Accounts and Service Accounts	17
Password Protection	18
THIRD PARTY RISK MANAGEMENT	19
Third Party Security	19
SECURITY CHANGE AND CONFIGURATION MANAGEMENT	20
Information Technology Committee	20
Patch Management	20
Acceptable Encryption	21
Hardening Standards	22

Threat and Vulnerability Management	23
End-Point Protection	23
Managed Endpoint Detection and Response	23

PROGRAM COMPLIANCE	24
Compliance Measurement	24
Exceptions	24
Non-Compliance	24

INTRODUCTION TO INFORMATION SECURITY PROGRAM

Purpose

This Information Security Program aims to provide a framework for information systems and security at (insert company name here), including guidelines for the deployment, maintenance, and acceptable usage of information systems and technological resources.

Specific implementations and custom policies and procedures could be suited to the needs of the implementing company, which is responsible for minimizing security risk per their specific risk profiles and business models. (insert company name here) ownership recognizes that operations and critical functions depend on information systems, including hardware, software, network capabilities, and related services.

This document defines requirements and standards for employees and other personnel to ensure that these systems remain available, reliable, and secure. In addition, it designates roles and responsibilities to ensure that the stated requirements and standards are maintained and/or exceeded.

Background

(insert company name here) has invested in information technology and systems comprising computer and telephone hardware, software, and data to support commercial operations. These systems are critical corporate assets, and every employee is responsible for their preservation, maintenance, and proper use.

(insert company name here) proprietary assets include its hardware, software, network resources, and all information contained therein. As a result, all users will be aware of the rules and requirements that govern their use of mentioned information system resources. All staff must be involved and cooperate to ensure that these resources operate in a secure, reliable, and efficient manner.

Scope

The terms “information systems” and “technology resources” as defined by (insert company name here) include the data, equipment, and processes in (insert company name here) ownership and under its control.

This document covers all automated information systems and technology capabilities, including all hardware, software, network resources, and the data residing therein that are owned, leased, or operated by (insert company name here). This includes but is not limited to email systems, internet access, online services, computer networks, voice mail systems, and computer systems.

This Information Security Program also covers systems operated by third party service providers on (insert company name here)'s behalf. The standards and requirements outlined in this program apply to all employees, contractors, consultants, temporary employees, and other workers at (insert company name here), including personnel affiliated with third party service providers.

Roles and Responsibilities

This section outlines the roles and responsibilities of the Information Technology Department concerning information systems and technology resources.

The Information Technology Department (either in-house or outsourced) is responsible for maintaining control over (insert company name here) internal computer systems to ensure the proper use of technology. The department is also responsible for ensuring that appropriate safeguards are in place to protect critical systems and confidential information.

Responsibilities of the Information Technology Department/Function include

- Administrates (insert company name here)'s Information Systems, Security Policy, and other Procedures;
- Manages software purchasing, equipment inventory and monitoring, and outsourced vendors that constitute (insert company name here)'s Information Systems;
- Manages employee onboarding providing logins and passwords in line with existing cybersecurity policies;
- Monitors activity on the network and reports on any activities outside the scope of company policies;
- Controls access for the remote user(s) or vendor(s) who need to connect to (insert company name here)'s network;
- Maintains authorized users list for the different systems on the (insert company name here) computer network.

- Verifies that all employees and other personnel who access the (insert company name here) computer network have a legitimate business purpose for the information;
- Documents all user issues, user requests, equipment installation, and equipment failures in the (insert ticketing system name here) ticketing system;
- Coordinates maintenance and repair for all hardware;
- Provides information, consultation, and assistance to any (insert company name here) employees regarding IT Systems;
- Recommends security procedures to employees and other personnel with access information on the (insert company name here) computer network.

ACCESS MANAGEMENT

User Accounts

The user accounts created for business will be active employee accounts and service accounts used by the IT Department to manage the computer network.

The IT Department will facilitate an annual review of all accounts in collaboration with Corporate Management to ensure that each account on the network has a legitimate need, that the duties assigned to the user ID are accurate, and that each account is assigned to an active employee or is a service account actively used by the IT Department.

Any exclusions will be acknowledged and approved by management. When possible, active network user accounts must be associated with active payroll and billing listings. All terminated personnel and accounts no longer needed will be removed within 24 hours of notification from management or the HR Department.

DATA PROTECTION

Data Classification

All employees are responsible for protecting data and information owned by (insert company name here), whether it exists in physical or digital formats.

The following classification will provide guidance on how to handle data securely and ethically.

- Public Information, defined as data intended for general public use and pre-designated for external distribution. Disclosure of the data is not expected to harm (insert company name here).
- Confidential Information, defined as sensitive information requiring strong controls to ensure confidentiality, integrity, and availability. Confidential information is any information that needs to be limited to a particular team within (insert company name here). Disclosure, alteration, or destruction could cause serious damage to (insert company name here)'s reputation, valuation, and/or provide a competitive disadvantage.

Data Loss Prevention

Content inspection and a centralized management framework are accepted Data Loss Prevention (DLP) solutions for identifying, monitoring, and protecting data in use (e.g., endpoint actions), data in motion (e.g., network actions), and data at rest (e.g., data storage).

DLP solutions will be implemented to detect and prevent any attempts to copy or send to unauthorized users sensitive data, whether the action occurs intentionally or unintentionally, without authorization and/or without the requisite level of protection.

The DLP solution will log incidents centrally for review. All unsuitable activities will be assessed and, where appropriate, escalated via the security incident management process.

The business will identify high-risk data as sensitive and likely to have a significant impact if handled inappropriately and deemed in-scope for protection.

Examples of data of high risk can include

- Credit card details, bank account numbers, and other financial identifiers;

- Names, addresses, social security numbers, email addresses, telephone numbers, and combinations of personally identifiable information;
- Documents that have been explicitly marked as Confidential or Restricted;
- Any Sales data, forecasts, or employee data;
- (insert company name here) Intellectual Property that, if leaked, would adversely affect the company's competitive advantage;

(This isn't an exhaustive list. Insert additional elements based on your company's specific activity.)

The Chief Information Security Officer, IT Committee, or equivalent level management or committee will approve changes to the DLP product configuration.

Data Breach Identification System Logging and Monitoring

Identifying a data breach or security incident is the process of analyzing an event and determining whether it can be classified as an incident. An incident is an adverse event and usually implies either harm or an attempt to harm (insert company name here)'s computer network.

(insert company name here) employees are the first line of defense for protecting the company and its data from security incidents; therefore, it is critical any suspected incident is communicated immediately to the IT Department. Employees may call, email, or submit a help desk ticket to report an incident.

All (insert company name here) employees will be required to report a suspected security incident to the IT Department as soon as possible. Any employee alleged to have negligently reported security incidents will be investigated for non-compliance with this policy, as explained in the section "Program Compliance."

The IT Department has the responsibility to routinely examine events to determine their impact and potential for harm and is ultimately responsible for identifying an incident.

Data Breach Management

As soon as a theft, data breach, or exposure containing (insert company name here) protected data or sensitive data is confirmed, the process of removing all access to that resource will be the responsibility of the Management or IT Department.

Cooperation with Forensic Investigators

In agreement with the (insert company name here) cyber insurance, the (insert cyber insurance provider name here) should reach out to an approved breach counsel. The breach counsel would assign a forensic IT expert who is also an approved vendor by the insurer. Having breach counsel retain the experts preserves such reports as confidential documents that are not discoverable in litigation.

(insert company name here) will notify Risk Strategies as well about the breach.

(insert company name here) will provide forensic investigators and experts access to determine how the breach or exposure occurred, the categories of data involved, and the internal/external individuals and/or organizations impacted. The investigators will analyze the breach or exposure to determine the root cause.

Develop a Communication Plan

The CEO, Executive Management, or the (insert company name here) Communications, Legal, and HR departments are to decide how to communicate the breach, with the assistance of the IT Department.

Approved messages can be communicated to internal employees, the public, and/or people impacted by the breach or exposure.

Enforcement

Any (insert company name here) personnel found in violation of this Information Security Program may be subject to disciplinary action, up to and including termination of employment. Any third party partner company found in violation may have their network connection terminated.

Encryption of the Hard Drive or Laptop

Company-owned devices that leave (insert company name here) facilities will be regarded as a direct threat to data loss or theft, as well as a potential compromise. All mobile devices will be protected with full-disk encryption to further protect (insert company name here)'s reputation and IT assets.

Additional compensatory controls will be introduced when full-disk encryption is not technically or operationally practicable to lessen the risks involved if devices are stolen or lost. Alternative compensating controls must be subjected to a risk assessment procedure and authorized by Upper-Level Management.

Multi-Factor Authentication

Multi-factor authentication (MFA) will be used when employees will access sensitive information from the Internet.

Technology Equipment Disposal

Technology Equipment refers to desktops, laptops, tablets, printers, copiers, monitors, servers, handheld devices, telephones, cell phones, disc drives or any storage device, network switches, routers, wireless access points, batteries, or backup tapes.

All Technology Equipment that has reached the end of its useful life will be sent to the IT Department for proper disposal.

The IT Department will securely erase all storage mediums in accordance with current industry best practices. All files and licensed software must be removed from equipment using disk sanitizing software that cleans the media by overwriting each and every disk sector of the machine with zero-filled blocks and meeting Department of Defense standards. Hard drives may also be removed and rendered unreadable (drilling, crushing, or other demolition methods).

No computer or technology equipment may be sold to any individual.

No Technology Equipment will be disposed of via skips, dumps, landfills, etc.

The IT Department will label the equipment after performing the disk wipe. The label must include the date and the name of the technician who performed the operation.

Technology Equipment with non-functioning memory or storage technology will have the memory or storage device removed, and it will be physically destroyed.

DATA BACKUPS AND DISASTER RECOVERY

Backup Plan

All data that has ongoing business value regardless of data classification or location will be backed up. The IT Department will be responsible for all backups of information and will verify the integrity of the backup upon its completion.

Backup Methods and Frequency

The IT Department will perform Incremental daily backups and full weekly backups that are also synced to the cloud. Weekly backups are to be taken on (insert day and time here). Incremental backups are to be taken at (insert day and time here) outside of normal business hours.

Backups must be segmented from the corporate network to minimize the risk of corporate network compromise also affecting backups.

Backup Validation

On an annual basis, the IT Department will be in charge of testing or certifying backups and restores. Validation testing must include recovering at least one critical-to-business file from each server. Documentation of successful and failed backup attempts and proven recoverability status will be part of the testing.

EMPLOYEE MANAGEMENT

Shared Device Workstation

Employees will use shared workstations only for business purposes. The employee will log off of the workstation after usage.

Remote Access

Employees, contractors, vendors, and agents with remote access privileges to (insert company name here)'s corporate network will be considered responsible for ensuring that their remote access connection is treated with the same care as the user's on-site connection.

(insert company name here) employees, contractors, vendors, and agents (hereafter referred to as "authorized users") will have restricted access to the Internet for recreational purposes over the company network. Encrypted communication methods like Virtual Private Networks (VPNs) must be used to control secure remote access.

Whenever remote access technologies connect to (insert company name here) internal networks, devices must have the latest version of anti-virus software installed.

External authorized users must be examined at least once a year, if not more often.

Social Engineering

Unauthorized personnel attempting to obtain access to secret information from (insert company name here) owned and operated sites are known as physical social engineering assaults.

Unauthorized personnel may impersonate managers, supervisors, or department heads as contractors, consultants, or IT staff. They may provide credentials and other documents proving that they have been employed to undertake specific tasks.

Other attempts to obtain employee IDs and passwords to various systems and applications may be conducted via email or phone calls. Employees must call management to confirm that the individual or their objective is authentic.

Employees must never give out their usernames and passwords. If it looks that a social engineering attack has been attempted or made, the IT department and/or the department manager will be informed right away.

At all times, visitors and contractors will be escorted or supervised.

Equipment

All equipment and resources belonging to (insert company name here) will be tracked and maintained. Wherever possible, (insert company name here) will employ asset tags to record each piece of equipment's unique asset number.

All equipment will be returned to managers, supervisors, or Human Resources representatives upon an employee's leave.

Employee Training/ User Awareness

A Security Awareness training program will be conducted (insert frequency here) to ensure that all (insert company name here) employees are aware of corporate standards and their responsibility for information security.

The Security Awareness training program should include the following requirements:

- All employees will be required to attend or participate in Security Awareness Training at their start date or onboarding training and (insert frequency here) thereafter.
- The (insert company name here) IT Department will conduct periodic security awareness testing through controlled social engineering initiatives.
- Failing training or testing will result in additional Security Awareness training.
- Multiple sequential failures may result in disciplinary action.

IT Prohibited Use

The following activities are prohibited. During their legitimate employment tasks, employees may be exempted from these restrictions (e.g., systems administration staff may need to disable a host's network access if that host is disrupting production services).

The lists below are by no means exhaustive but attempt to provide a framework for activities that fall into unacceptable use.

The following activities are strictly prohibited, with no exceptions:

- Violations of copyright, trade secret, patent, or other intellectual property rights, or similar laws or regulations, including, but not limited to, the installation or distribution of "pirated" or other software products that are not appropriately licensed for use by (insert company name here).
- Accessing data, a server, or an account for any purpose other than conducting (insert company name here) business, even if you have authorized access.
- Revealing your account password to others or allowing use of your account by others. This includes family and other household members when work is being done at home.
- Using any type of network monitoring that intercepts data not intended for the employee's host, unless it is part of the employee's normal job.
- Circumventing user authentication or security of any host, network, or account.
- Interfering with or denying service to any user other than the employee's host (for example, denial of service attack).
- Providing information about or lists of (insert company name here) employees to parties outside of the organization.

Wireless Communication

(insert company name here) IT Resources will connect to the wireless network using a Mobile Device Management (MDM) server for all wireless infrastructure devices. To connect to the MDM server, the IT Department must first approve the device and then input it into the MDM server.

All other wireless devices, including personal cellphones, will be separated from the business network and connected to the (insert name of WiFi network designated for guests).

When communicating on any cellular device related to (insert company name here) business, employees will follow the established company policies and/or procedures. This includes, but is not limited to, wireless networks in homes and other WiFi situations outside of (insert company name here)'s property.

Clean Desk

Employees will ensure that confidential information in physical or electronic form is secure in their work area at the end of the day and when the employee is expected to be absent for an extended period.

When an employee's workspace is empty, computer workstations (including laptops) must be locked. Employees' computer workstations will be set to log them out after 15 minutes of inactivity.

(insert company name here) management has the authority to conduct random checks on staff to ensure that they follow this policy. Checks might be done after hours or when a work area is left unattended for an extended period of time.

PASSWORD REQUIREMENTS

Password Standards

When creating and preserving passwords for (insert company name here)'s systems or applications, the following standards must be observed:

- Each work-related account requires a separate, unique password.
- Users are not permitted to use work-related passwords for personal accounts.
- Passwords must be at least fifteen (15) characters in length.
- Passwords must contain at least one (1) upper case letter, one (1) lower case letter, one (1) number, and one (1) special character.
- Passwords must be changed every 180 days or if there is reason to assume they have been compromised.
- System lockout will occur after five (5) consecutive incorrect login attempts (i.e., invalid user ID/password combinations).
- Users must contact the Help Desk or IT Department to reset their password.
- A user's previous twelve (12) passwords are not re-usable.

Password Standards for Administrative Accounts and Service Accounts

User accounts with elevated privileges obtained through group memberships or programs will have a separate password from their regular user accounts to access system-level privileges.

A user administrator account's password is held to a higher level.

The following password requirements will be followed for creating and maintaining passwords for (insert company name here)'s administrative/service accounts:

- Passwords must be at least fifteen (15) characters in length.
- Passwords must be changed every 90 days or if there is reason to assume they have been compromised.

Password Protection

Passwords must not be disclosed to anybody. Any user who suspects that his or her password has been compromised must report the situation immediately and change all passwords. Passwords will not be written down in an accessible position or left on "sticky notes" affixed on or under a computer. Employees are not to use programs' or web browsers' "Remember Password" features.

Passwords will be stored only in "password managers" authorized by (insert company name here) IT Department.

THIRD PARTY RISK MANAGEMENT

Third Party Security

(insert company name here) management should perform due diligence and ensure that third parties who have access to company resources, such as internal systems and sensitive data, have adequate security controls in place. Any further information security concerns will be evaluated by the IT department in collaboration with (insert company name here) management.

As needed, more information on the IT Department's specific duties in terms of third party and vendor partnerships will be added to this Information Security Program.

A basic non-disclosure agreement (NDA) must be executed by the third party if communications with third parties entail the release of sensitive (insert company name here) information. The information given to these third parties must be confined to themes that are directly linked to the project or business relationship in question, and the disclosure must be approved by management.

Depending on the risk associated with the access provided, (insert company name here) may reserve the right to inspect the security measures in place on third party-connected systems. (insert company name here) may also have the right to terminate network connections with any third party systems that do not meet these conditions.

SECURITY CHANGE AND CONFIGURATION MANAGEMENT

Information Technology Committee

(insert company name here)'s IT Department will have a monthly meeting with management to discuss IT and security issues. The Information Technology Committee's mission is to create and maintain a procedure for documenting proposed information system modifications and improve (insert company name here)'s general IT and security hygiene.

The committee will determine which important stakeholders will be responsible for reviewing and approving suggested changes.

Changes that are deemed urgent do not require permission from the IT Committee before being implemented. Management can make out-of-band approvals instead.

Patch Management

Software flaws can make a system unusable, introduce security flaws, or corrupt essential system components or data. Such flaws in security can leave (insert company name here)'s computer systems unsecured and vulnerable to viruses, access, and criminal usage of information by unauthorized parties.

Installing a software "patch" or updates to remedy the vulnerability is the remedial measure to mitigate such risks, guaranteeing that (insert company name here)'s computer systems' security and availability are not threatened.

(insert company name here) will implement a Patch Management Program to reduce the risks involved with patching any identified software flaws by:

- Identifying risks posed by known software vulnerabilities and taking appropriate action;
- Implementing and evaluating patch management processes to determine whether they are adequate to minimize risk;
- Defining and delegating patch management tasks to authorized employees, including early detection of vulnerabilities and related patches, patch evaluation and testing, timely implementation of patches appropriate to the environment, and tracking of both implemented and rejected patches;

- Documenting any decisions to install or reject specific patches;
- Allowing independent third party audits to be performed to provide assurance that vulnerabilities have been identified and appropriate patches have been installed.

The IT Department will be responsible for overseeing (insert company name here)'s Patch Management Program. This department will also conduct examinations of any patches to (insert company name here) software products before implementation.

The IT Department will evaluate each patch ahead of installation to ensure that it will work as planned and is compatible with other (insert company name here) systems. Evaluation and testing must also guarantee that installing a patch or software update does not reopen or create new vulnerabilities that have already been fixed.

The IT Department will ensure that the system may be recovered after the patch has been implemented if problems arise after installation.

The IT Department will record the installation of approved fixes. As a source of reference, a central file will be kept.

(insert company name here) must not apply any patches to any of the company's computers or network devices. Authorized IT staff will apply and distribute patches to all of (insert company name here)'s computers and network devices. All patch software will be used solely for business purposes. Employees who are found to be in violation of this policy may face disciplinary action.

The IT Department will be responsible for continuously monitoring and identifying software vulnerabilities and related fixes using the information provided by (insert company name here)'s different software vendors, security vendors, subscription alerts, and other service bureaus.

Acceptable Encryption

(insert company name here) may employ encryption to safeguard confidential and critical information in transit and storage. Encryption may be required when confidential information is sent over a public communication network or maintained in a system that is not otherwise protected by robust access controls (e.g., internal systems that are protected by password authentication and restricted access privileges do not require encryption).

The following conditions must be met when encryption is required:

- The IT Department must authorize encryption products. Software based on algorithms that have been reviewed, tested, and validated independently is recommended.
- Encryption keys, like passwords, are always considered confidential information. As a result, key access will be limited, and they must be encrypted when sent over public networks or stored systems labeled as insecure.

Hardening Standards

The operating system (OS) is a piece of system software that manages computer hardware and software resources while also providing common services to computer programs.

(Microsoft is the most popular desktop operating system, but this section covers the basic security needs for any operating system. Update these standards to match your company's OS.)

- The IT Department will maintain a security template for initial hardening procedures on new OS devices.
- Following initial hardening procedures, (insert company name here) IT will perform a vulnerability scan of the system.
- The IT Department will disable all remote access unless users or groups have permission to log on to Remote Desktop Services.
- Users will use centralized authentication for all desktops.
- Any local administrative accounts or guest accounts will be renamed and protected with strong passwords.
- All user accounts will change passwords at least every 180 days.
- Malware scanning software must run on desktops.
- Auto-run access on removable media devices will be disabled.
- Secure wireless capabilities will be configured.
- The IT Department will implement controls on removable devices/media.
- Local administrative privileges will be removed.
- Idle timeout will be enabled.

- All devices must use updated, secure, stable, and supported versions of operating systems and related software.

Employees will not install applications that would operate within the (insert company name here) network on (insert company name here) computing equipment unless management first approves the software request.

The IT Department will be responsible for collecting and tracking licenses, testing new software for compatibility and conflict, and installing it.

Threat and Vulnerability Management

The vulnerability detection procedure must encompass all (insert company name here) computer processing system assets.

Vulnerabilities must be fixed within the time frames outlined in the table below:

Infrastructure Risk Criticality	Flaw/Vulnerability Severity Not Allowed + Calendar Days to Remediate Flaw/Vulnerability			
Site Facing	Critical	High	Medium	Low
Internet + Extranet	7 Days	15 Days	30 Days	60 Days
Intranet	15 Days	30 Days	60 Days	90 Days

End-Point Protection

All computers connecting to (insert company name here) systems must have virus prevention software that keeps track of known vulnerabilities and stores information on the computers linked to the (insert company name here) network.

Virus protection will be included in the standard configuration of (insert company name here) PCs.

Managed Endpoint Detection and Response

In addition to managing incident detection and response at network endpoints, enterprise detection and response (EDR) solutions are recommended. Wherever possible, real-time intelligence and

other features will be gathered, including remote event monitoring and device quarantining, automated protection and isolation, and forensic evidence capture.

PROGRAM COMPLIANCE

Compliance Measurement

Compliance to this program shall be verified by the head of the IT Department or management using a variety of ways, including but not limited to business tool reports, internal and external audits, and feedback to the program and/or policy owner.

Exceptions

Any deviation from the program must be approved in advance by the Board of Directors or Executive Management.

The authorizers must understand the amount of risk and accept it after receiving approval from Management or an approved Committee.

Non-Compliance

If an employee has violated this program, they may face disciplinary action, up to and including termination, as outlined in the employee Handbook.